

Foundation of Computer Security

Books

- Essential Reading

- Cryptography and Network Security by B. A. Forouzan, 2nd Ed., McGrawHill
- William Stallings, Cryptography and Network Security: Principles and Practice, Prentice Hall

- Supplementary Reading

- Douglas R. Stinson, *Cryptography: Theory and Practice*, Chapman and Hall
- J. Katz and Y. Lindell, *Introduction to Modern Cryptography*, CRC press , 2008

Secure System

- A system which is providing the services required by a user accurately and preventing the illegal use of system resources is called a **secure system**.

Cryptography

- **Cryptography** is the study of techniques for preventing access to sensitive data by parties who are not authorized to access the data.
- **Cryptanalysis** is the study of techniques for breaking cryptographic system
- **Cryptology** = Cryptography + Cryptanalysis

Terminology

- ***Cipher/Cryptosystem*** – a function for encrypting and decrypting data
- Plaintext*** – A message in its natural format readable by an attacker
- Ciphertext*** – Message altered to be unreadable by anyone except the intended recipients
- Key*** – Sequence that controls the operation and behavior of the cryptographic algorithm
- Keyspace*** – Total number of possible values of keys in a crypto algorithm

threat – a potential for violation of security

attack – an assault on system security, a deliberate attempt to evade security services

plaintext (data file or messages)



encryption

ciphertext (stored or transmitted safely)



decryption

plaintext (original data or messages)

- A cryptosystem is a 5-tuple consisting of (E, D, M, K, C) , Where,

E is an encryption algorithm

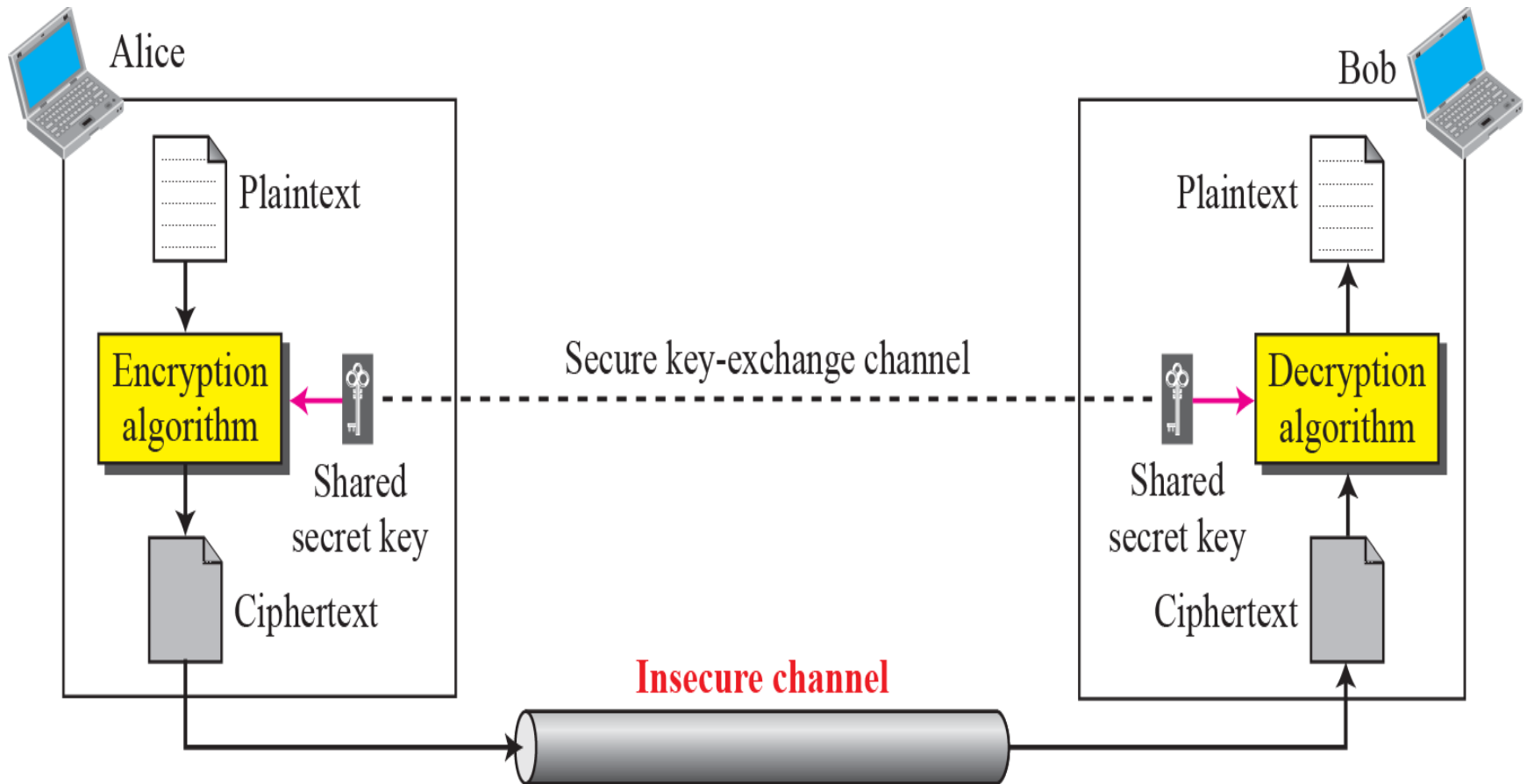
D is an decryption algorithm

M is the set of plaintexts

K is the set of keys

C is the set of ciphertexts

General idea of traditional cipher



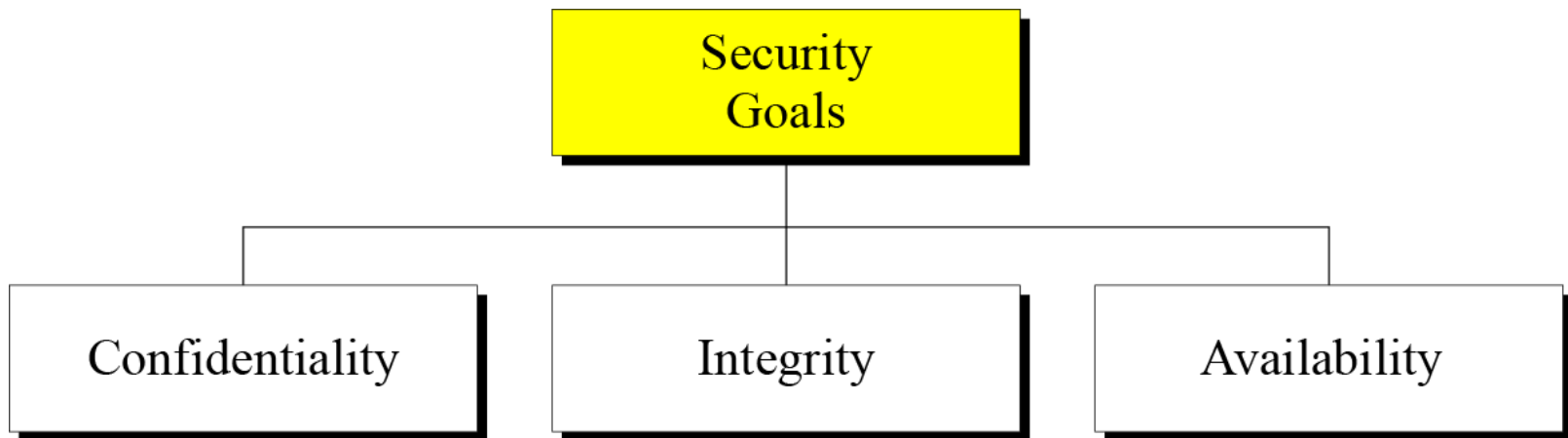
Kerckhoffs' Principle

- A cipher must not be required to be secret, and it must be able to fall into the hands of the enemy without inconvenience
- The only secrecy involved with a cryptosystem should be the key

Security Goals

- There are three security goals:
- Confidentiality
- Integrity
- Availability

- Taxonomy of security goals



Examples of Security Requirements

- confidentiality – student grades
- integrity – patient information
- availability – authentication service

Confidentiality

- aims to protect data from unauthorized disclosure
- usually based on encryption

Integrity

- Information needs to be changed constantly.
- Integrity means that changes need to be done only by authorized entities and through authorized mechanisms.
 - aims to detect modification and replay
 - provides assurance that data received are exactly as sent by the sender

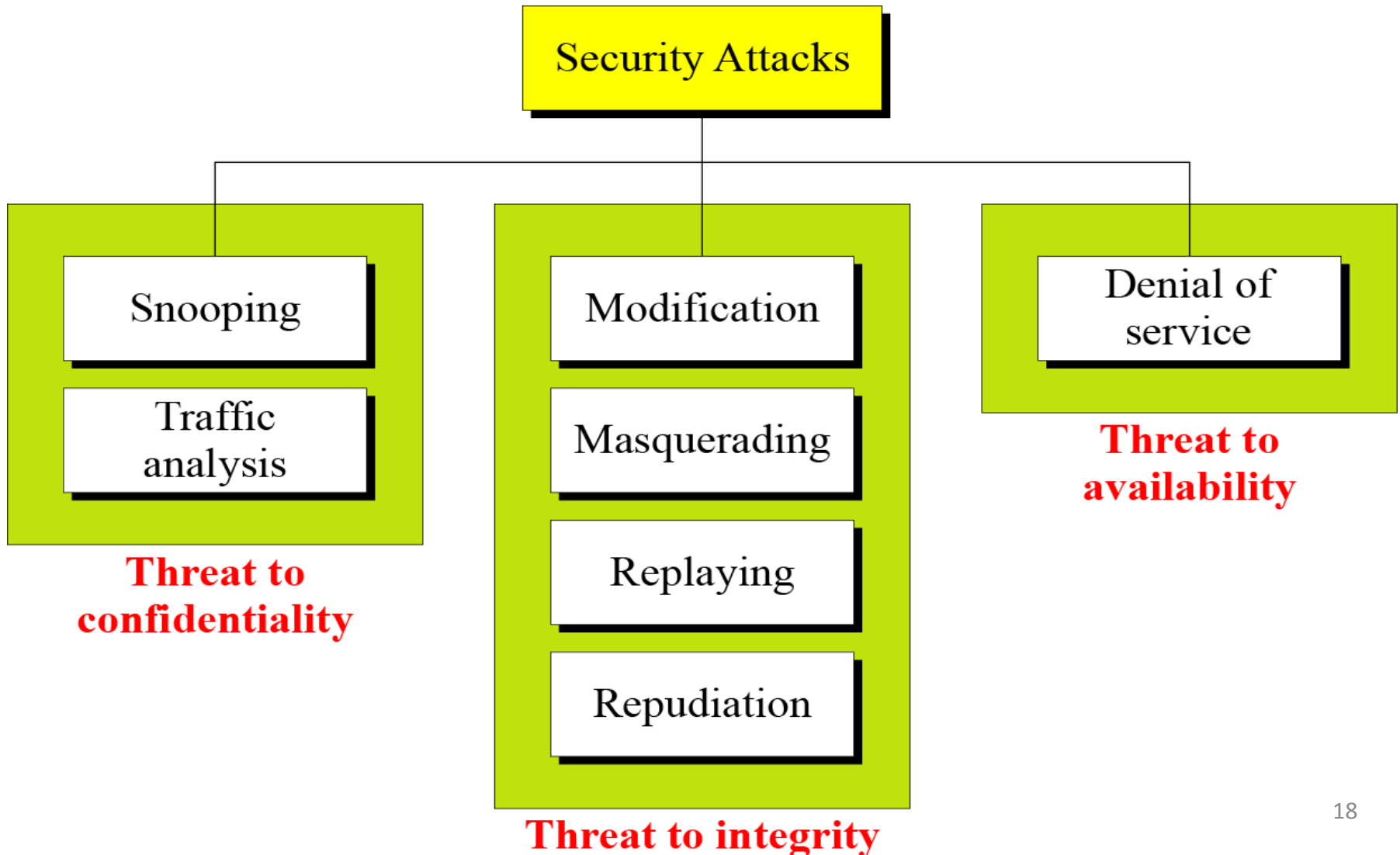
Availability

- The information created and stored by an organization needs to be available to authorized entities.
- Information needs to be constantly changed, which means it must be accessible to authorized entities.

Attacks

- The three goals of security: confidentiality, integrity, and availability, can be threatened by security attacks.
- Attacks Threatening Confidentiality
- Attacks Threatening Integrity
- Attacks Threatening Availability
- Passive versus Active Attacks

Taxonomy of attacks with relation to security goals



Attacks Threatening Confidentiality

- **Snooping** refers to unauthorized access to or interception of data.
- **Traffic analysis** refers to obtaining some other type of information by monitoring online traffic.

Attacks Threatening Integrity

- **Modification** means that the attacker intercepts the message and changes it.
- **Masquerading** or **spoofing** happens when the attacker impersonates somebody else.
- **Replaying** means the attacker obtains a copy of a message sent by a user and later tries to replay it.
- **Repudiation** means that sender of the message might later deny that she has sent the message; the receiver of the message might later deny that he has received the message.

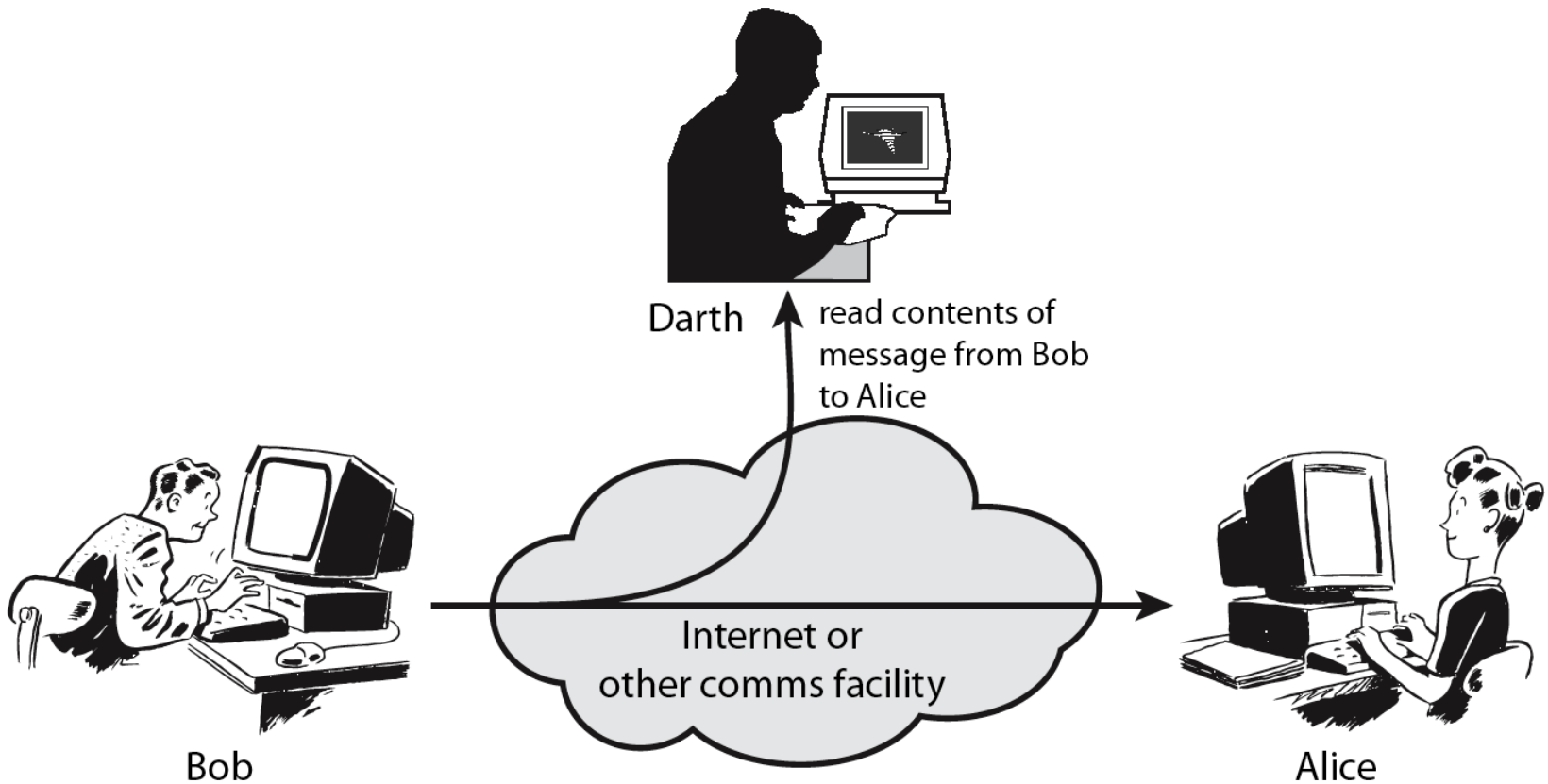
Attacks Threatening Availability

- Denial of service (DoS) is a very common attack.
- It may slow down or totally interrupt the service of a system.

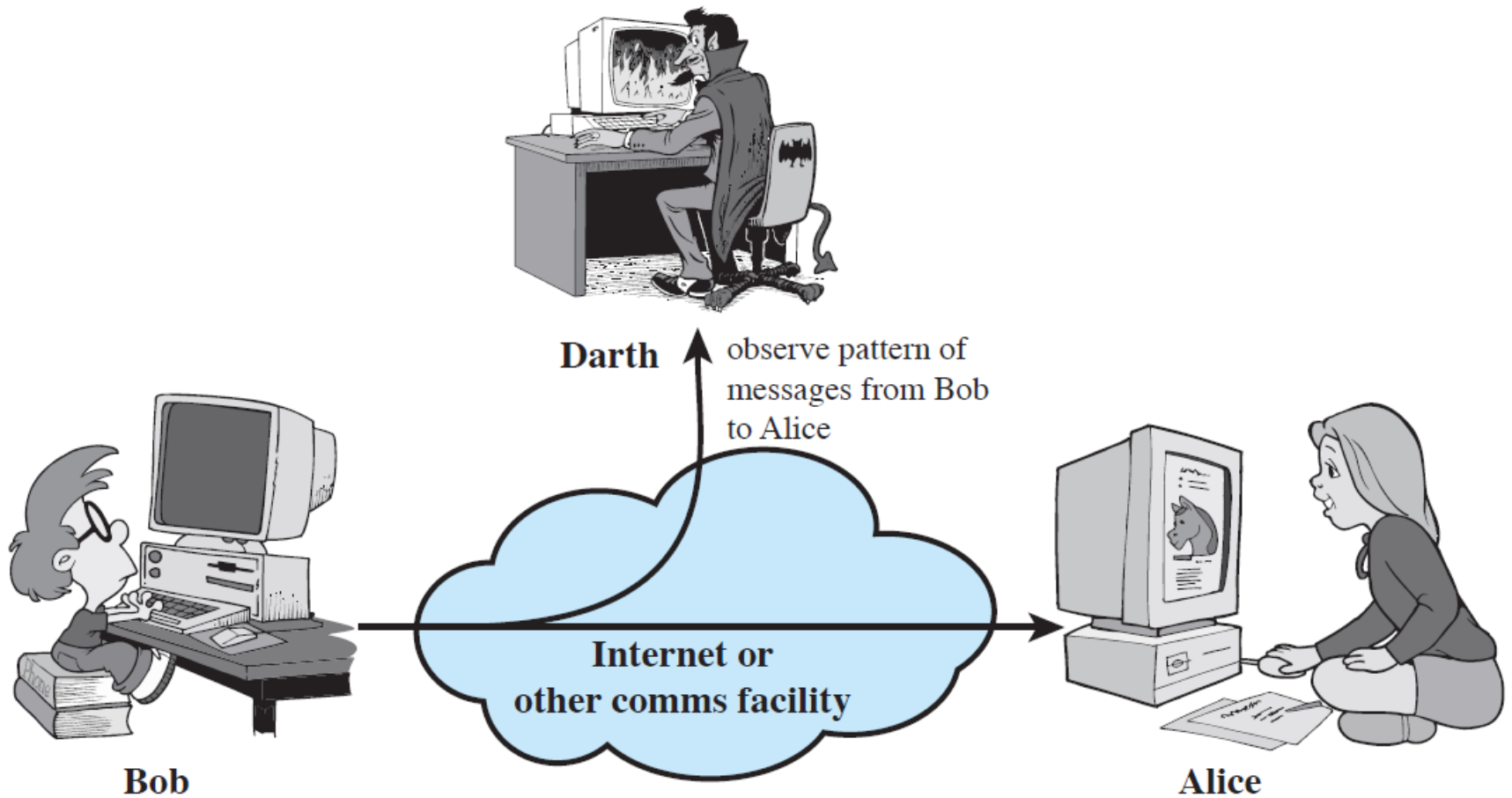
Security Attacks

- Passive attacks
 - Obtain message contents
 - Monitoring traffic flows
- Active attacks
 - Masquerade of one entity as some other
 - Replay previous messages
 - Modify messages in transit
 - Add, delete messages
 - Denial of service

Passive Attacks (Release of Message Contents)



Passive Attacks (Traffic Analysis)



Active Attacks (Masquerade)

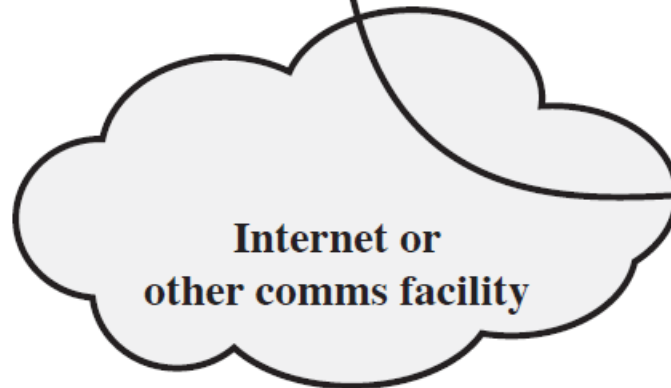


Darth

Message from Darth
that appears to be
from Bob



Bob

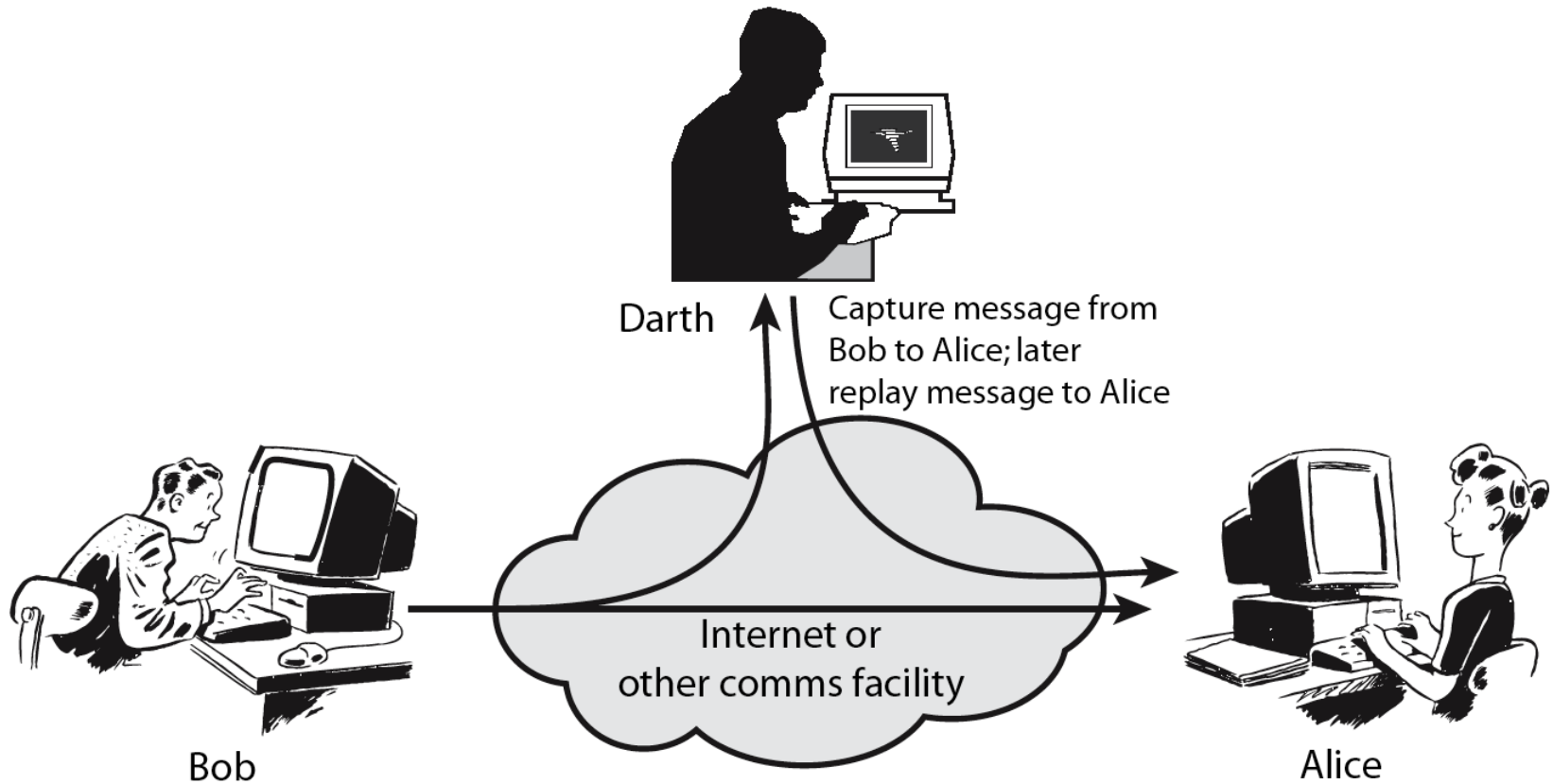


Internet or
other comms facility

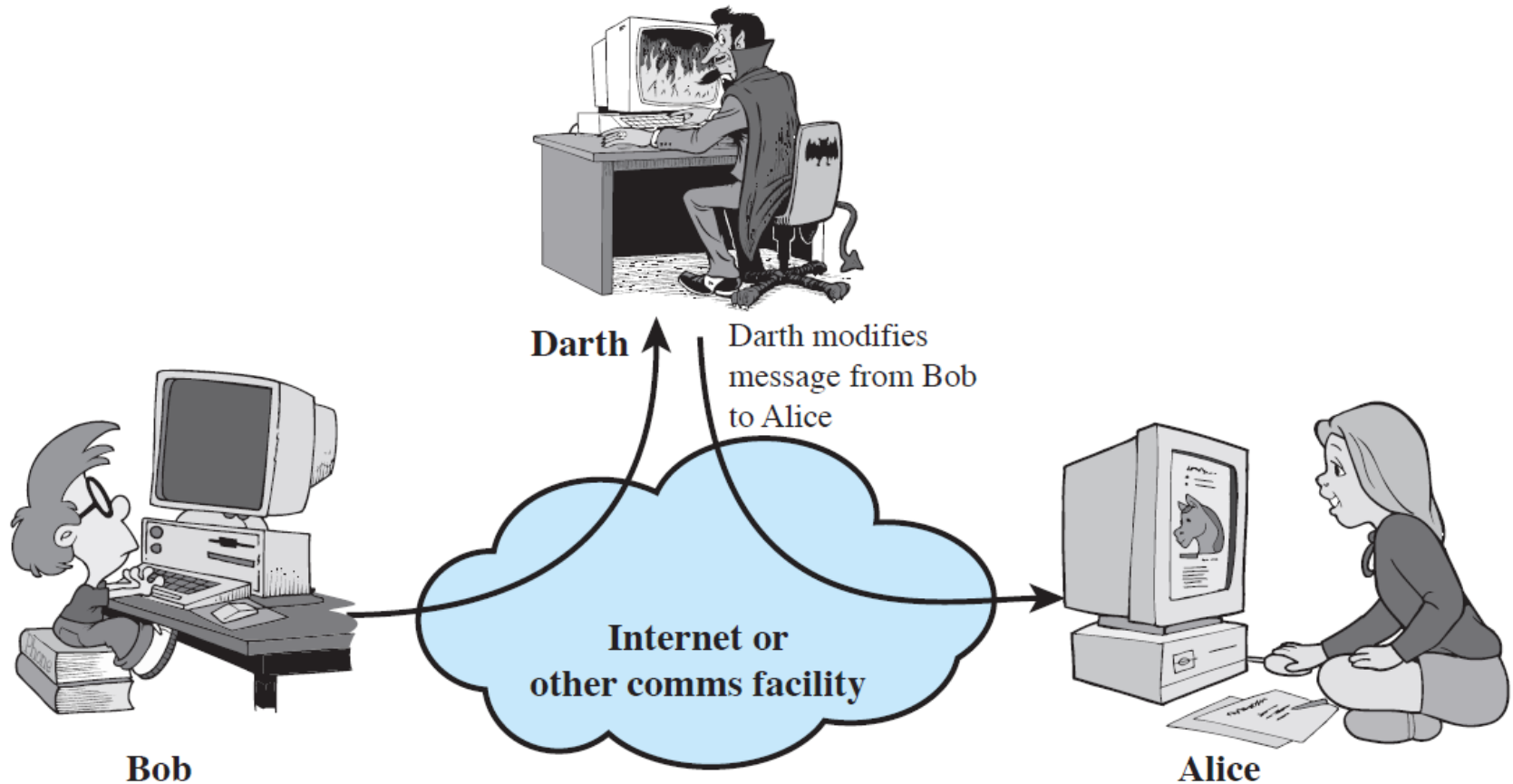


Alice

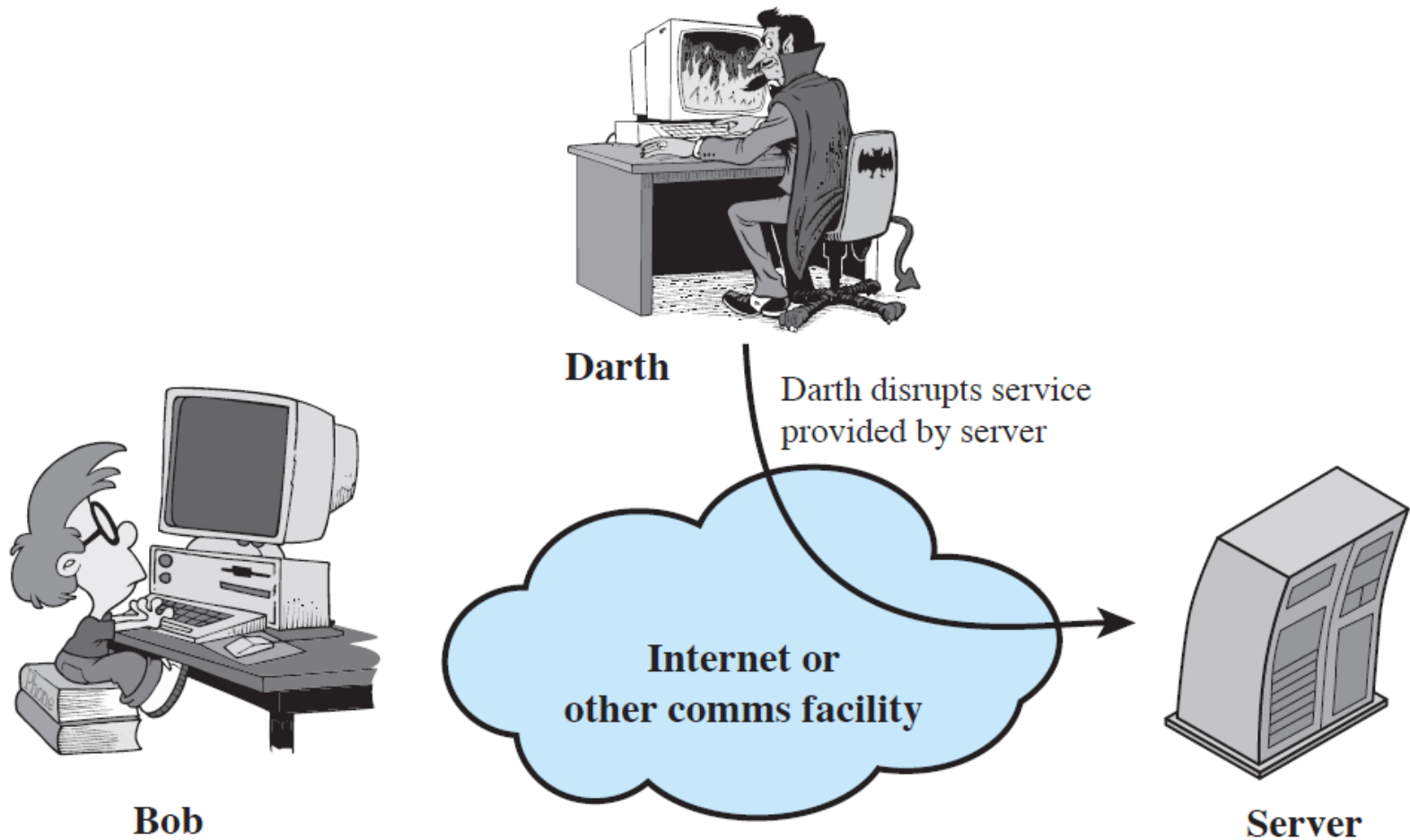
Active Attacks (Replay)



Active Attacks (Modification of Messages)



Active Attacks (Denial of Service)



Passive Versus Active Attacks

<i>Attacks</i>	<i>Passive/Active</i>	<i>Threatening</i>
Snooping Traffic analysis	Passive	Confidentiality
Modification Masquerading Replaying Repudiation	Active	Integrity
Denial of service	Active	Availability

Security Attacks II

- **Interruption:** This is an attack on availability
- **Interception:** This is an attack on confidentiality
- **Modification:** This is an attack on integrity
- **Fabrication:** This is an attack on authenticity

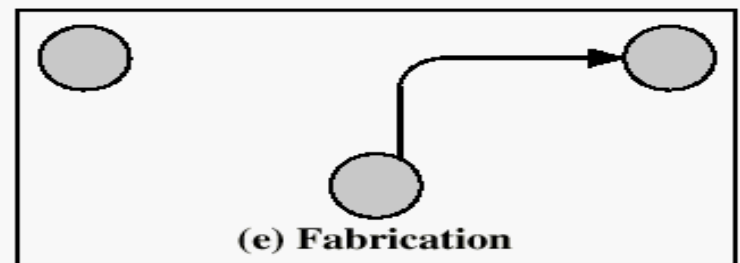
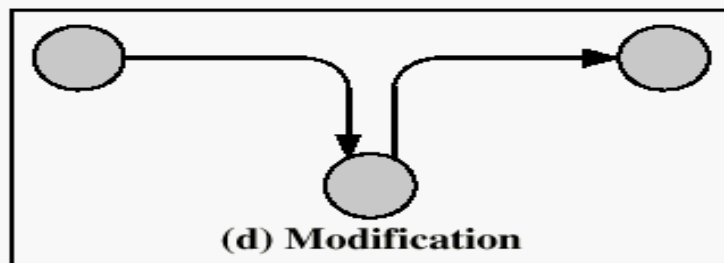
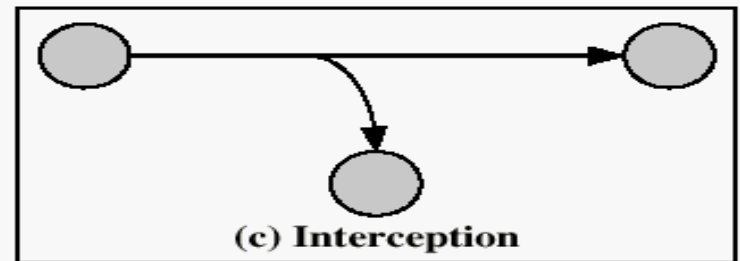
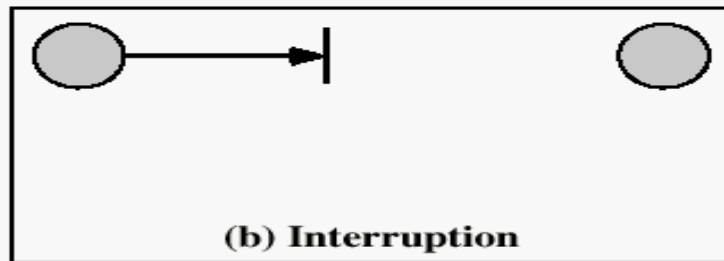
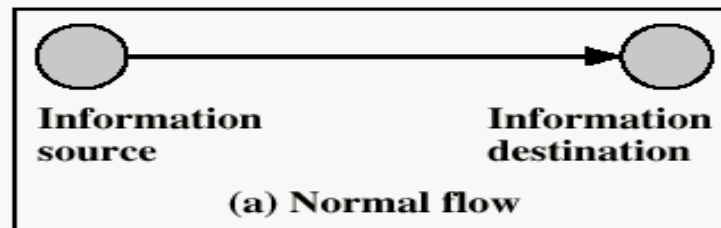


Figure 1.1 Security Threats

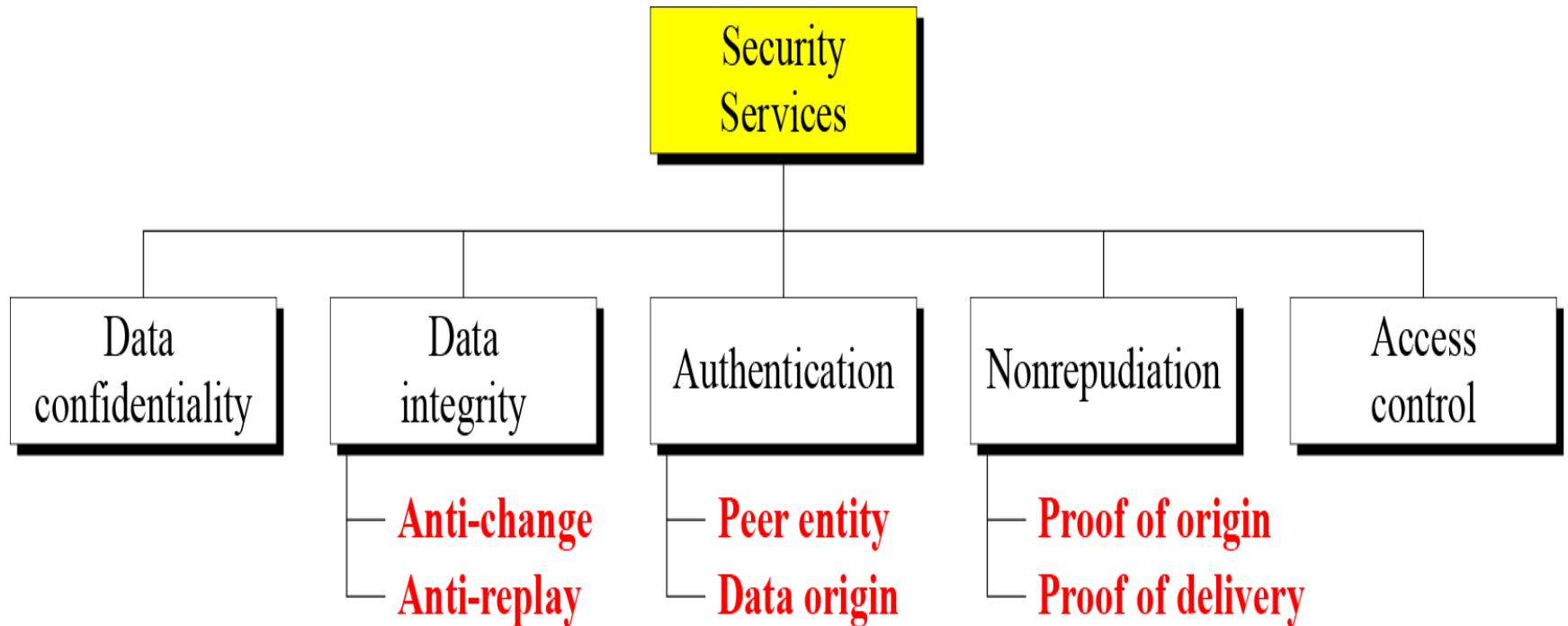
Methods of Defense

- Encryption
- Software Controls (access limitations in a data base, in operating system protect each user from other users)
- Hardware Controls (smartcard)
- Policies (frequent changes of passwords)
- Physical Controls

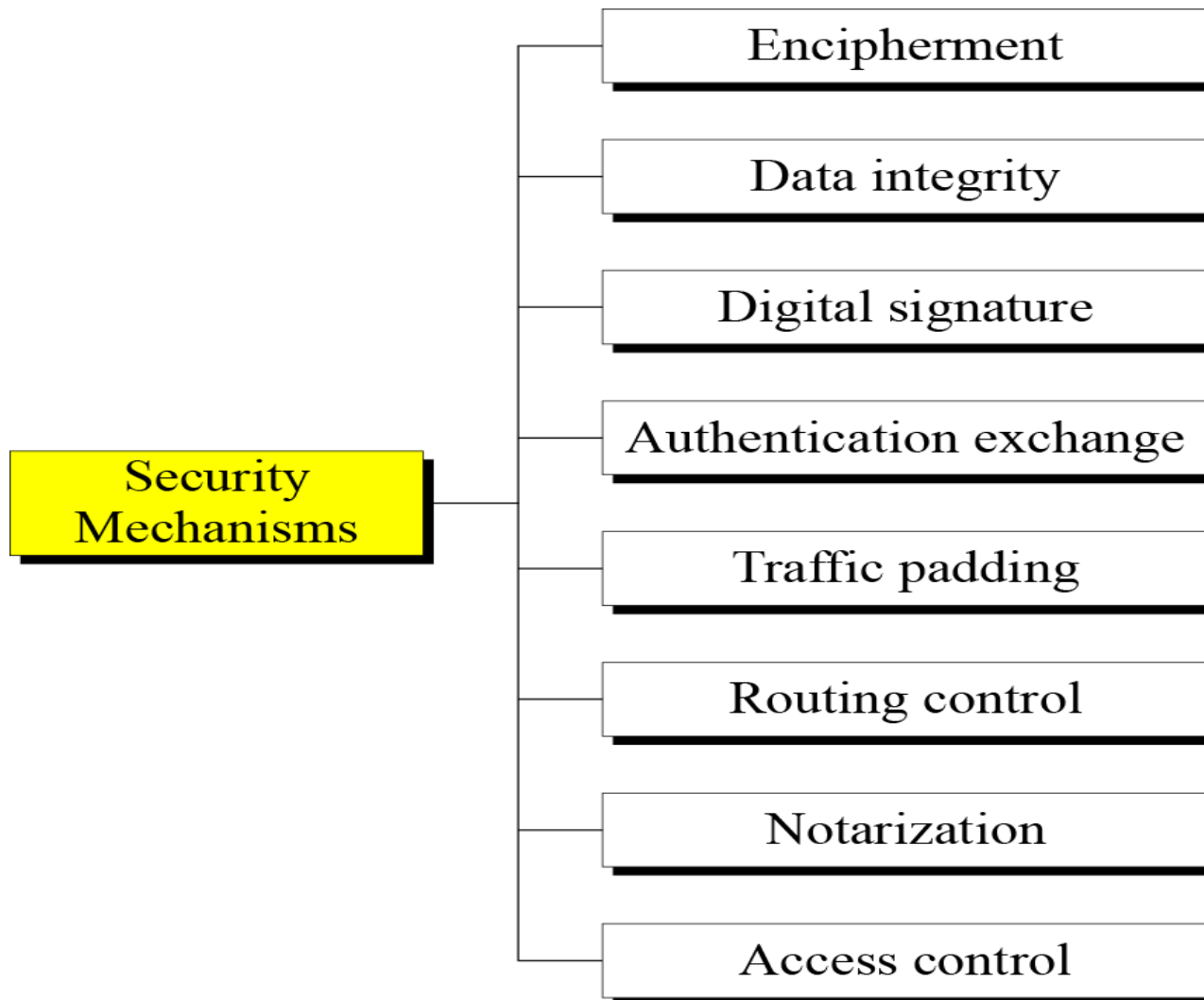
Security Services and Mechanisms

- ITU-T provides some security services and some mechanisms to implement those services.
- Security services and mechanisms are closely related because a mechanism or combination of mechanisms are used to provide a service

Security services



Security Mechanism



Relation between Services and Mechanisms

<i>Security Service</i>	<i>Security Mechanism</i>
Data confidentiality	Encipherment and routing control
Data integrity	Encipherment, digital signature, data integrity
Authentication	Encipherment, digital signature, authentication exchanges
Nonrepudiation	Digital signature, data integrity, and notarization
Access control	Access control mechanism

Techniques

- The actual implementation of security goals needs some techniques. Two techniques are prevalent today:
 - Cryptography
 - steganography.

Cryptography

- Cryptography, a word with Greek origins, means “secret writing.”
- It is the science and art of transforming messages to make them secure and immune to attacks.

Steganography

- The word steganography, with origin in Greek, means “covered writing,” in contrast with cryptography, which means “secret writing.”